Informe Técnico de Implementación y Operación de Seguridad: Despliegue de Kaspersky Endpoint Security (EDR/XDR), SIEM Wazuh y Gestión de Servicios en GLPI Cloud para PagoClaro Fintech S.A.S. (Caso Práctico C05)

Jonathan David Quintero Villamizar

Wendy Yolanny Jaimes Lugo

Unidades Tecnológicas de Santander (UTS)

Facultad de Ciencias Naturales e Ingenierías

Ética del Hacking / SOC Nivel 1

Equipo Docente UTS

Bucaramanga, Santander, Colombia

2026

Resumen

El presente informe documenta el diseño, la implementación y la validación de una arquitectura de monitoreo y respuesta orientada a la pasarela de pagos PagoClaro Fintech S.A.S. (Caso C05), desarrollada para un Centro de Operaciones de Seguridad de Nivel 1 (SOC N1). El trabajo integra tres plataformas: el sistema de gestión de eventos e información de seguridad (SIEM) Wazuh, desplegado y validado en un laboratorio virtualizado con un servidor central y dos endpoints (Linux y Windows); Kaspersky Endpoint Security Cloud con capacidades de detección y respuesta (EDR/XDR), configurado para un parque de 20 nodos; y GLPI Cloud, empleado como mesa de ayuda alineada con ITIL v4 y para el inventario automatizado de activos. Se describen la integración de los eventos de Kaspersky hacia Wazuh mediante Syslog en formato CEF, tres reglas personalizadas de detección, una respuesta activa de registro, evaluaciones de configuración (SCA), la consulta de vulnerabilidades, las políticas de control de dispositivos y web, y el esquema de acuerdos de nivel de servicio. Asimismo, se analiza la alineación con la Ley 1273 de 2009 y la Ley Estatutaria 1581 de 2012, se identifican los riesgos y limitaciones del laboratorio y se propone un plan de expansión para 20 equipos. Los resultados evidencian la detección y la trazabilidad de los escenarios probados; su paso a producción requiere dimensionamiento, ajuste de reglas y pruebas de carga.

Palabras clave: ciberseguridad, SIEM, Wazuh, Kaspersky Endpoint Security, EDR/XDR, GLPI, ITIL, SOC, hábeas data, delitos informáticos

Tabla de Contenido

1. Resumen Ejecutivo y Marco Contextual 7
1.1 Resumen Ejecutivo 7
1.2 Contexto de la Infraestructura de PagoClaro Fintech S.A.S. 8
1.3 Herramientas Empleadas y Aportes al Proyecto 8
2. Despliegue del SIEM Wazuh 9
2.1 Objetivo y Alcance de la Implementación 9
2.2 Infraestructura del Laboratorio 10
2.3 Arquitectura y Comunicaciones 10
2.4 Instalación y Comprobación de los Componentes Centrales 12
2.5 Despliegue de los Agentes 13
2.5.1 Agente Linux 13
2.5.2 Agente Windows 14
2.6 Monitoreo de Integridad de Archivos (FIM) 16
2.7 Reglas Personalizadas 17
2.7.1 Regla 100501: Cambio en Archivo Crítico 18
2.7.2 Regla 100502: Instrucción con Privilegios SUPERUSER 18
2.7.3 Regla 100503: Evento VPN Simulado 19
2.8 Respuesta Activa 19
2.9 Evaluación de Configuración (SCA) 21
2.10 Gestión de Vulnerabilidades 22
2.11 Prueba de Recepción de Eventos en Windows 23
2.12 Visualización y Consulta de Resultados 24
2.13 Matriz de Validación 25
3. Despliegue y Configuración de Kaspersky EDR/XDR 25
3.1 Arquitectura del Agente Kaspersky Endpoint Security 25
3.2 Matriz de Módulos de Protección Activos 26
3.3 Estrategia de Aislamiento y Análisis de Amenazas (EDR) 26
3.4 Políticas de Control de Acceso y Periféricos 27
3.5 Configuración de Exclusiones de Análisis 27
4. Integración Kaspersky–SIEM Wazuh (CEF/Syslog) 28
4.1 Arquitectura del Flujo de Eventos de Seguridad 28
4.2 Formato de Trama CEF Emitido por Kaspersky 28
4.3 Reglas Personalizadas de Correlación en Wazuh 29

4.4 Pruebas de Validación de Cadenas de Ataque 30
4.5 Resultados de la Integración EDR–SIEM 30
5. Despliegue y Operación de GLPI Cloud (Mesa de Ayuda ITIL) 30
5.1 Arquitectura del Servicio GLPI Cloud 30
5.2 Configuración de la Estructura Organizacional y Roles 31
5.3 Gestión del Inventario Automatizado mediante GLPI Agent 31
5.4 Categorización ITIL y Niveles de Servicio (SLA) 31
5.5 Registro y Trazabilidad de Tickets Gestionados 32
6. Marco Legal y Cumplimiento Normativo en Colombia 32
6.1 Alineación Normativa para la Pasarela PagoClaro Fintech 32
6.2 Matriz de Delitos Informáticos: Ley 1273 de 2009 33
6.3 Cumplimiento de Hábeas Data: Ley Estatutaria 1581 de 2012 33
7. Análisis de Riesgos, Problemas Encontrados y Plan de Expansión 34
7.1 Análisis de Riesgos 34
7.2 Problemas Encontrados y Soluciones Aplicadas 34
7.3 Dimensionamiento y Plan de Despliegue para 20 Equipos 35
7.4 Limitaciones y Lecciones Aprendidas 36
8. Conclusiones y Recomendaciones Técnicas 37
8.1 Conclusiones del Proyecto 37
8.2 Recomendaciones para Fases Futuras 38
Referencias 39
Anexo A. Inventario de Activos del Componente Wazuh 41
Anexo B. Matriz de Riesgos del Componente Wazuh 42
Anexo C. Aporte Técnico para el Informe de Incidente 43
Anexo D. Alcance y Reglas de Compromiso del Componente Wazuh 45
Anexo E. Organización de Evidencias y Configuraciones 47
Anexo F. Declaración de Uso de Herramientas de Inteligencia Artificial 48

Índice de Tablas

Tabla 1. Distribución del Inventario de Nodos Tecnológicos 8
Tabla 2. Herramientas Empleadas, Versiones y Aportes....8
Tabla 3. Equipos Virtuales del Laboratorio....10
Tabla 4. Componentes de la Plataforma Wazuh....11
Tabla 5. Flujos de Comunicación del Laboratorio....11
Tabla 6. Configuración del Agente Wazuh en el Endpoint Linux....14
Tabla 7. Reglas Personalizadas Implementadas en Wazuh 17
Tabla 8. Resultados de la Evaluación SCA por Endpoint 21
Tabla 9. Vistas Incorporadas de Wazuh Utilizadas 24
Tabla 10. Matriz de Validación del Componente Wazuh....25
Tabla 11. Módulos de Protección de Kaspersky Endpoint Security Considerados en el Proyecto 26
Tabla 12. Políticas de Control Web y de Dispositivos Periféricos 27
Tabla 13. Campos de la Trama CEF de Ejemplo....29
Tabla 14. Resultados de las Pruebas de Validación del Motor Kaspersky 30
Tabla 15. Matriz de Roles y Estructura en GLPI Cloud 31
Tabla 16. Acuerdos de Nivel de Servicio (SLA) Configurados 32
Tabla 17. Muestra de Tickets Atendidos en el Laboratorio SOC N1 32
Tabla 18. Mapeo de Delitos Informáticos y Controles de Mitigación....33
Tabla 19. Problemas Encontrados y Soluciones Aplicadas 35
Tabla 20. Plan de Despliegue Propuesto para 20 Equipos....35
Tabla A1. Inventario de Activos del Laboratorio 41
Tabla A2. Activos de Información Asociados 41
Tabla B1. Matriz de Riesgos: Aporte del Componente Wazuh....42
Tabla C1. Ficha Técnica del Incidente de Prueba....43
Tabla E1. Archivos Técnicos de la Implementación 47

Índice de Figuras

Figura 1. Estado de los Servicios Centrales y Listado de Agentes Registrados en Wazuh 13
Figura 2. Registro de Conexión del Agente Wazuh en wj-c05-api01 14
Figura 3. Listado de Agentes en el Servidor Wazuh con el Endpoint Windows Activo 15
Figura 4. Resumen del Agente WJ-C05-WIN01 en el Dashboard de Wazuh 16
Figura 5. Verificación de la Restauración del Archivo config.ini 17
Figura 6. Verificación de la Eliminación del Rol de Prueba en PostgreSQL 19
Figura 7. Ejecución de la Respuesta Activa y Registro Generado para la Regla 100503 21
Figura 8. Resumen y Detalle de Vulnerabilidades del Agente wj-c05-api01 23
Figura 9. Evento de Prueba Generado en Windows y Visualizado en Wazuh 24

Informe Técnico de Implementación y Operación de Seguridad: Despliegue de Kaspersky Endpoint Security (EDR/XDR), SIEM Wazuh y Gestión de Servicios en GLPI Cloud para PagoClaro Fintech S.A.S. (Caso Práctico C05)

1. Resumen Ejecutivo y Marco Contextual

1.1 Resumen Ejecutivo

El presente informe técnico compila y formaliza las actividades ejecutadas para el fortalecimiento de la infraestructura tecnológica y operativa de la pasarela de pagos digital PagoClaro Fintech S.A.S. (Caso C05). En el desarrollo de las Fases 3 y 4 del proyecto se desplegó una arquitectura integral de protección y monitoreo conformada por el sistema de gestión de eventos e información de seguridad (SIEM) Wazuh (Wazuh, s. f.-e), la plataforma de protección de endpoints Kaspersky Endpoint Security Cloud con capacidades de detección y respuesta (EDR/XDR; Kaspersky Lab, 2023) y la plataforma de gestión de servicios e inventario GLPI Cloud, alineada con la guía de buenas prácticas ITIL v4 (AXELOS, 2019; Teclib', 2023).

El objetivo central de la intervención consistió en elevar la madurez en ciberseguridad y la capacidad de respuesta ante incidentes del Centro de Operaciones de Seguridad de Nivel 1 (SOC N1), garantizando la alineación con los marcos normativos colombianos —Ley 1273 de 2009, de delitos informáticos, y Ley Estatutaria 1581 de 2012, de protección de datos personales (Congreso de la República de Colombia, 2009, 2012)— y con los estándares internacionales ISO/IEC 27001:2022 (International Organization for Standardization [ISO], 2022) y PCI DSS v4.0 (PCI Security Standards Council [PCI SSC], 2022).

El documento se organiza en ocho secciones. La Sección 2 describe el despliegue y la validación del SIEM Wazuh; la Sección 3, la configuración de Kaspersky EDR/XDR; la Sección 4, la integración entre ambas plataformas mediante Syslog en formato CEF; la Sección 5, la

operación de GLPI Cloud como mesa de ayuda; la Sección 6, el cumplimiento normativo en Colombia; la Sección 7, el análisis de riesgos, los problemas encontrados y el plan de expansión; y la Sección 8, las conclusiones y recomendaciones técnicas.

1.2 Contexto de la Infraestructura de PagoClaro Fintech S.A.S.

PagoClaro Fintech S.A.S. opera un entorno híbrido distribuido en tres segmentos críticos. El parque de activos está conformado por un total de 20 nodos heterogéneos, cuya distribución se presenta en la Tabla 1.

Tabla 1

Distribución del Inventario de Nodos Tecnológicos

Categoría de activo	Sistema operativo	Cant.	Función operativa en la pasarela	Criticidad
Estaciones administrativas	Windows 11 Pro de 64 bits	11	Terminales de tesorería, contabilidad y atención al cliente	Media-Alta
Estaciones de desarrolladores	macOS Sonoma 14.x	5	Construcción de código, APIs y despliegues en entorno sandbox	Alta
Servidores backend/API	Ubuntu Server 22.04 LTS	4	Procesamiento de pagos, base de datos de tarjetas y SIEM	Crítica
Total		**20**		

1.3 Herramientas Empleadas y Aportes al Proyecto

Los resultados del proyecto se sustentan en las capacidades de tres plataformas. La Tabla 2 sintetiza el aporte de cada una, conforme a la documentación de sus fabricantes, de modo que los hallazgos de este informe puedan atribuirse con claridad a la herramienta que los hizo posibles.

Tabla 2

Herramientas Empleadas, Versiones y Aportes

Herramienta	Versión	Aporte al proyecto	Referencia
Wazuh (SIEM/XDR de código abierto)	Wazuh 4.14.9 (servidor y agentes)	Centralización de eventos de Linux y Windows; monitoreo de integridad de archivos (FIM); reglas personalizadas; respuesta activa; evaluación de configuración (SCA); detección de vulnerabilidades	Wazuh (s. f.-a, s. f.-c, s. f.-f)
Kaspersky Endpoint Security Cloud (EDR/XDR)	KES 12.3; Network Agent 14.2	Protección del endpoint frente a malware, control de dispositivos, web y aplicaciones, análisis de comportamiento, y detección y respuesta (EDR) con aislamiento de red	Kaspersky Lab (2023)
GLPI Cloud	GLPI 10.0.12; GLPI Agent 1.4	Mesa de ayuda alineada con ITIL v4, gestión de activos (CMDB), inventario automatizado, matrices de prioridad y acuerdos de nivel de servicio (SLA)	Teclib' (2023)

2. Despliegue del SIEM Wazuh

Esta sección documenta la implementación y validación del componente Wazuh en el laboratorio del Caso C05. Dicho componente fue implementado y documentado por Wendy Yolanny Jaimes Lugo, integrante del equipo de trabajo (véanse los Anexos A a F).

2.1 Objetivo y Alcance de la Implementación

El objetivo fue desplegar y validar un sistema de monitoreo de seguridad basado en Wazuh para el laboratorio representativo de PagoClaro (Caso C05). La solución permite centralizar eventos de equipos Linux y Windows, identificar modificaciones en archivos, evaluar configuraciones de seguridad, consultar hallazgos de vulnerabilidades y ejecutar una respuesta automática controlada.

El laboratorio representa parcialmente una organización de 10 empleados y 20 equipos. Se implementaron un servidor central Wazuh y dos endpoints monitoreados: un servidor Linux y una estación Windows. No se desplegaron físicamente los 20 agentes; su incorporación se contempla en el plan de expansión (véase la Sección 7.3). Las actividades comprendieron:

- Instalación y configuración del servidor central.
- Incorporación de agentes Linux y Windows.
- Configuración del monitoreo de integridad de archivos.
- Recolección de registros de PostgreSQL y de eventos simulados de VPN.
- Implementación de tres reglas personalizadas.
- Evaluación de configuración mediante SCA.
- Consulta de vulnerabilidades detectadas.
- Implementación de una respuesta activa de registro.
- Obtención y organización de evidencias técnicas.

Las pruebas se realizaron sobre máquinas virtuales del laboratorio y con datos ficticios. No se efectuaron escaneos ni pruebas de ataque contra sistemas externos. El evento de VPN se generó de forma sintética y se identificó expresamente como una simulación.

2.2 Infraestructura del Laboratorio

La implementación se realizó en VirtualBox sobre un equipo físico con procesador AMD Ryzen 5 7520U, arquitectura de 64 bits y 8 GB de memoria RAM. Debido a la memoria disponible, los endpoints Linux y Windows se utilizaron por turnos cuando fue necesario; por esta razón, algunas capturas muestran un agente desconectado mientras se validaba el otro. Los equipos virtuales se describen en la Tabla 3.

Tabla 3

Equipos Virtuales del Laboratorio

Equipo	Función	Sistema operativo	Dirección interna	Recursos asignados
wj-c05-wazuh	Servidor central Wazuh	Ubuntu Server 24.04 LTS	192.168.50.10/24	1 vCPU, 4 GB de RAM, disco virtual de 60 GB
wj-c05-api01	Endpoint Linux y PostgreSQL	Ubuntu Server 24.04 LTS	192.168.50.20/24	1 vCPU, 1 GB de RAM, disco virtual de 20 GB

Equipo	Función	Sistema operativo	Dirección interna	Recursos asignados
WJ-C05-WIN01	Endpoint Windows	Windows 10	192.168.50.30/24	1 vCPU, 2 GB de RAM, disco virtual de 50 GB

La versión utilizada del servidor y de los agentes fue **Wazuh 4.14.9**.

2.3 Arquitectura y Comunicaciones

El servidor central utiliza una arquitectura integrada, con los componentes de Wazuh instalados en una misma máquina (véase la Tabla 4).

Tabla 4

Componentes de la Plataforma Wazuh

Componente	Función
Wazuh server / manager	Recibir eventos, analizarlos y aplicar reglas
Wazuh indexer	Indexar y almacenar la información para su consulta
Wazuh dashboard	Presentar agentes, alertas y resultados de seguridad
Filebeat	Transportar las alertas del servidor al indexer
Agentes Wazuh	Recopilar información y eventos de los endpoints

Las máquinas virtuales se comunicaron mediante la red interna de VirtualBox denominada **SOC-C05**, con direccionamiento 192.168.50.0/24. Adicionalmente se emplearon adaptadores NAT para descargar instaladores y actualizaciones; por tanto, existía salida a Internet mediante NAT, y las pruebas se limitaron a la red interna y a las máquinas autorizadas. El laboratorio utilizó una sola subred interna. **No se implementaron VLAN reales**; la segmentación por VLAN que se presente en la arquitectura de la organización debe entenderse como una propuesta de despliegue. Los flujos de comunicación se resumen en la Tabla 5.

Tabla 5

Flujos de Comunicación del Laboratorio

Origen	Destino	Puerto/protocolo	Propósito
Agentes Linux y Windows	Wazuh manager	TCP 1514	Envío de eventos
Agentes	Wazuh manager	TCP 1515	Inscripción de agentes
Navegador del equipo anfitrión	Wazuh dashboard	TCP 443, mediante redirección local 8443	Consulta del panel
Equipo anfitrión	Servidor Wazuh	TCP 22, mediante redirección local 2222	Administración SSH
Equipo anfitrión	Endpoint Linux	TCP 22, mediante redirección local 2223	Administración SSH

El acceso al dashboard desde el equipo anfitrión se realizó mediante la siguiente dirección:

```
https://127.0.0.1:8443
```

2.4 Instalación y Comprobación de los Componentes Centrales

Se instaló Ubuntu Server LTS y posteriormente se desplegaron los componentes centrales de Wazuh. Su funcionamiento se verificó mediante el estado de los servicios y el acceso al dashboard. Los servicios comprobados fueron `wazuh-indexer`, `wazuh-manager`, `wazuh-dashboard` y `filebeat`. Para consultar el estado de los tres componentes principales se utilizó el comando:

```
systemctl is-active wazuh-indexer wazuh-manager wazuh-dashboard
```

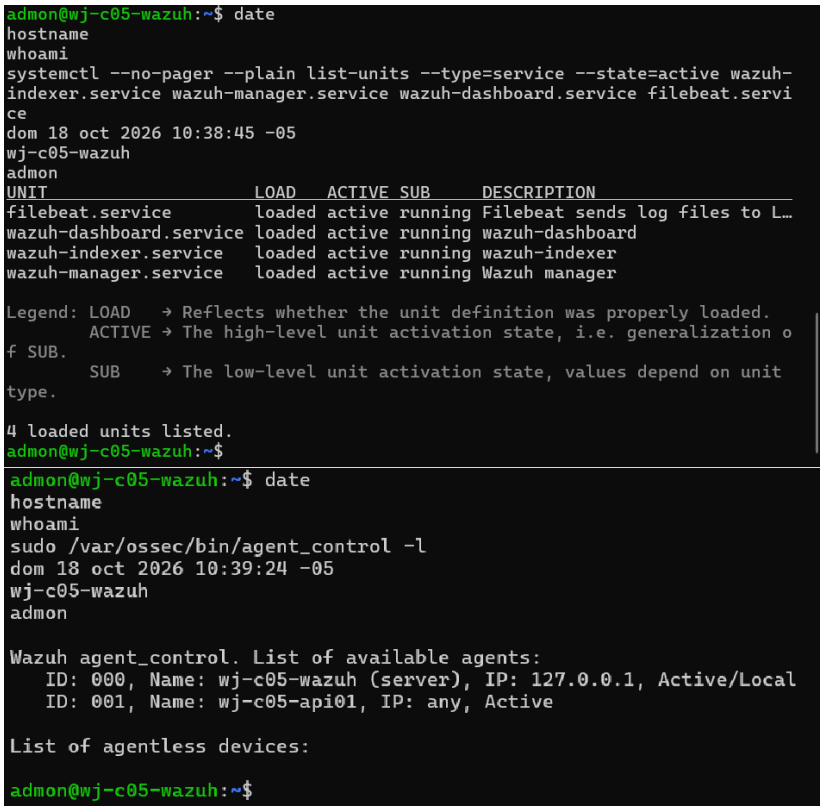
Asimismo, se comprobó el listado de agentes registrados:

```
sudo /var/ossec/bin/agent_control -l
```

La validación combinó la comprobación de servicios, el acceso a la interfaz web y la recepción de eventos; un servicio activo, por sí solo, no se consideró evidencia suficiente del funcionamiento completo (véase la Figura 1).

Figura 1

Estado de los Servicios Centrales y Listado de Agentes Registrados en Wazuh



2.5 Despliegue de los Agentes

2.5.1 Agente Linux

Se instaló el agente Wazuh en el equipo wj-c05-api01, configurando como servidor de destino la dirección 192.168.50.10. El endpoint quedó registrado con el identificador **001**. Sobre este equipo se configuraron el monitoreo de archivos de la aplicación ficticia, la recolección de registros de PostgreSQL y la lectura del archivo JSON utilizado para simular eventos de VPN (véase la Tabla 6).

Tabla 6

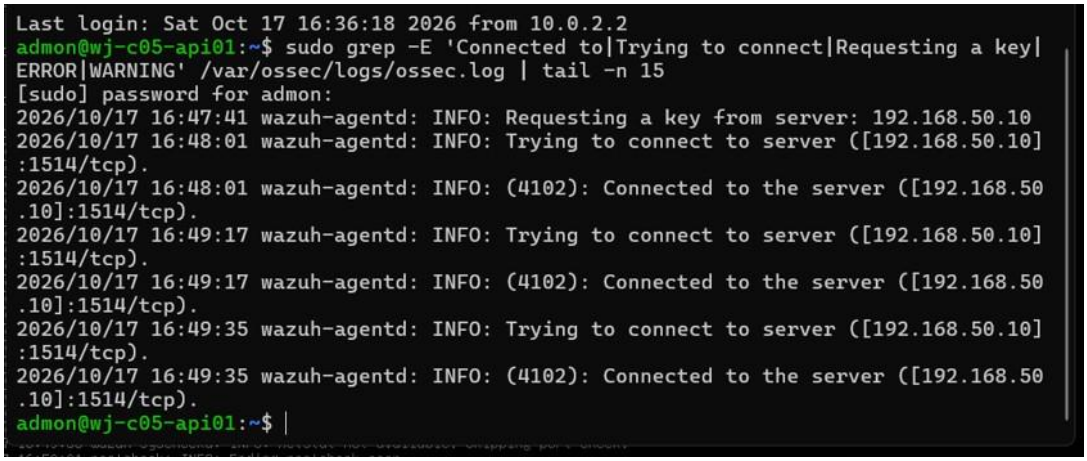
Configuración del Agente Wazuh en el Endpoint Linux

Elemento	Configuración
Nombre del agente	wj-c05-api01
Identificador	001
Servidor Wazuh	192.168.50.10
Directorio FIM	`/opt/pagoclaro/api`
Registro PostgreSQL	`/var/log/postgresql/postgresql-16-main.log`
Registro VPN simulado	`/var/log/pagoclaro-vpn-simulado.json`

La conexión del agente con el servidor se comprobó en el registro local del agente, como se muestra en la Figura 2.

Figura 2

Registro de Conexión del Agente Wazuh en wj-c05-api01



2.5.2 Agente Windows

Se instaló el agente Wazuh 4.14.9 en la máquina WJ-C05-WIN01, estableciendo como servidor de destino la dirección 192.168.50.10. El equipo quedó registrado con el identificador

002. El servicio se verificó mediante el comando `Get-Service WazuhSvc` y posteriormente se comprobó su estado *Active* desde el servidor y desde el dashboard (véanse las Figuras 3 y 4).

La configuración del agente incluye la recolección de los canales *Application*, *Security* y *System*, la evaluación SCA, el inventario del sistema y el monitoreo de integridad sobre rutas y claves de registro definidas en su configuración. La recepción de eventos y los resultados SCA se validaron mediante pruebas; la existencia de otras opciones habilitadas en el archivo de configuración no se presenta como prueba independiente de todas sus funciones.

Figura 3

Listado de Agentes en el Servidor Wazuh con el Endpoint Windows Activo

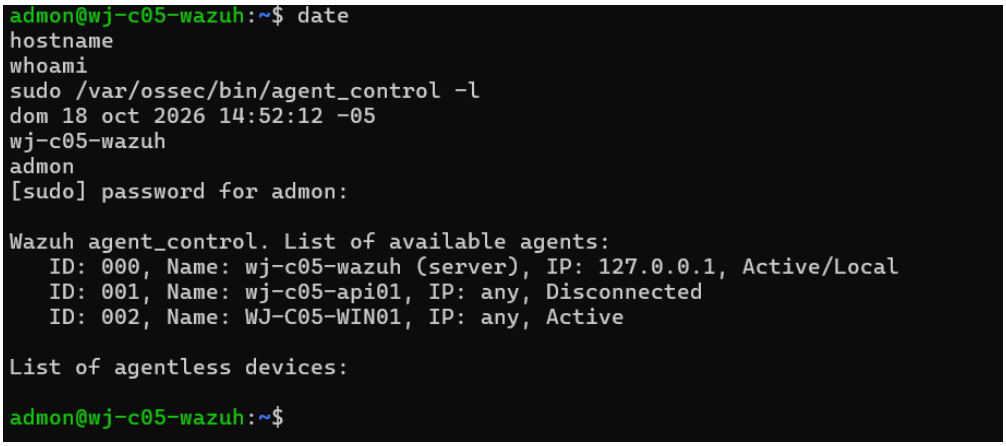
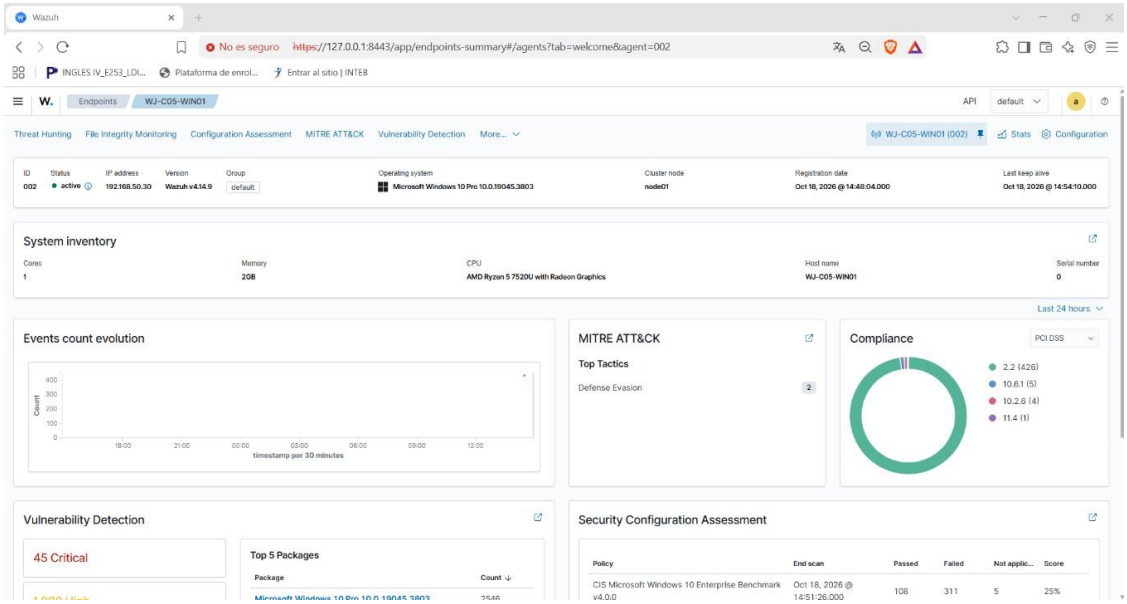


Figura 4

Resumen del Agente WJ-C05-WIN01 en el Dashboard de Wazuh



.

2.6 Monitoreo de Integridad de Archivos (FIM)

El módulo de monitoreo de integridad de archivos (FIM) permite identificar modificaciones en archivos y en sus atributos mediante comprobaciones programadas o en tiempo real, según la configuración aplicada (Wazuh, s. f.-c). En el agente Linux se configuró el siguiente directorio:

```
<directories check_all="yes" realtime="yes"
report_changes="yes">/opt/pagoclaro/api</directories>
```

El archivo utilizado en la prueba fue `/opt/pagoclaro/api/config.ini`, que contenía parámetros ficticios de una API de pagos. Se modificó de manera controlada el valor de `limite_transaccion` para comprobar la detección. Inicialmente se observó una alerta de modificación de integridad asociada a la regla incorporada **550**; posteriormente se implementó una regla personalizada para asignar mayor relevancia a los cambios sobre ese archivo

específico. Finalizada la prueba, se restauró el contenido original y se verificó su coincidencia con la copia de referencia (véase la Figura 5).

El resultado demuestra la detección de modificaciones sobre el archivo monitoreado. No demuestra que el cambio haya sido malicioso: dicha clasificación requiere comprobar su autorización y contexto.

Figura 5

Verificación de la Restauración del Archivo config.ini



2.7 Reglas Personalizadas

Se implementaron tres reglas personalizadas en el servidor Wazuh, resumidas en la Tabla 7 y elaboradas conforme al mecanismo de reglas y decodificadores personalizados de la plataforma (Wazuh, s. f.-b).

Tabla 7

Reglas Personalizadas Implementadas en Wazuh

ID	Nivel	Escenario	Condición principal
100501	12	Cambio en configuración de la API	Modificación FIM del archivo `config.ini`
100502	12	Instrucción privilegiada en PostgreSQL	Registro de `CREATE ROLE` o `CREATE USER` con `SUPERUSER`
100503	12	Acceso VPN simulado	Evento JSON exitoso, país distinto de CO y marca de simulación

Se utilizaron mecanismos de análisis existentes de Wazuh, incluido el decodificador JSON. **No se desarrollaron tres decodificadores nuevos; el desarrollo personalizado consistió en tres reglas.**

2.7.1 Regla 100501: Cambio en Archivo Crítico

La regla se definió en el archivo `pagoclaro_c05_rules.xml`:

```
<group name="syscheck,pagoclaro,c05,">
  <rule id="100501" level="12">
    <if_sid>550</if_sid>
    <field name="file" type="pcre2">^/opt/pagoclaro/api/config\.ini$</field>
    <description>PagoClaro C05: cambio en configuracion critica de la API de
pagos.</description>
  </rule>
</group>
```

Esta regla especializa la detección de integridad sobre un archivo de interés para el caso. El analista debe contrastar la modificación con los cambios autorizados y revisar el contenido alterado antes de clasificar el evento.

2.7.2 Regla 100502: Instrucción con Privilegios SUPERUSER

La regla se definió en el archivo `pagoclaro_c05_postgresql.xml`:

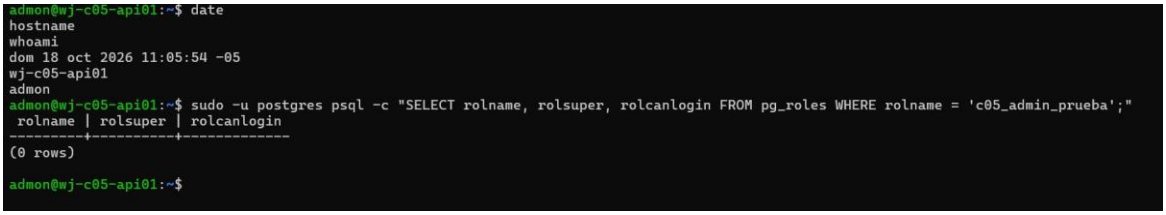
```
<group name="pagoclaro,c05,postgresql,">
  <rule id="100502" level="12">
    <location type="pcre2">/var/log/postgresql/postgresql-16-
main\.log$</location>
    <match type="pcre2">(?i)\bCREATE\s+(ROLE|USER)\s+.*\bSUPERUSER\b</match>
    <description>PagoClaro C05: instruccion de creacion de cuenta PostgreSQL
con privilegios SUPERUSER.</description>
  </rule>
</group>
```

Para la prueba se creó el rol ficticio `c05_admin_prueba` con atributos `NOLOGIN` y `SUPERUSER`. Se comprobó su estado en PostgreSQL, se retiraron los privilegios y posteriormente se eliminó el rol (véase la Figura 6). La regla detecta el texto de una instrucción registrada; la confirmación de que la operación tuvo éxito se obtuvo mediante la consulta del catálogo de PostgreSQL, no únicamente por la alerta. Esta prueba representa un escenario de privilegios

administrativos inesperados y permite demostrar la detección, la revisión y la reversión controlada.

Figura 6

Verificación de la Eliminación del Rol de Prueba en PostgreSQL



2.7.3 Regla 100503: Evento VPN Simulado

La regla se definió en el archivo `pagoclaro_c05_vpn.xml`:

```
<group name="pagoclaro,c05,vpn,">
  <rule id="100503" level="12">
    <decoded_as>json</decoded_as>
    <field name="event_type">^vpn_login$</field>
    <field name="vpn_result">^success$</field>
    <field name="country" negate="yes">^CO$</field>
    <field name="simulation">^yes$</field>
    <description>PagoClaro C05 LAB SIMULADO: acceso VPN exitoso desde pais
distinto de Colombia.</description>
  </rule>
</group>
```

El evento utilizado fue el siguiente:

```
{"event_type":"vpn_login","vpn_result":"success","country":"US","simulation":"
yes","vpn_user":"admin_ficticio"}
```

Dicho evento se escribió en un archivo monitoreado por el agente y se verificó su aparición en Wazuh. No se implementó una VPN real ni se determinó una ubicación mediante geolocalización: el país fue un dato suministrado en el evento sintético. La prueba valida la recolección, la interpretación y la detección de un patrón definido.

2.8 Respuesta Activa

Se implementó una respuesta activa vinculada a la regla **100503**. Wazuh permite ejecutar acciones automáticas ante condiciones definidas; para scripts personalizados se configura el comando en el servidor y se instala el ejecutable en el endpoint correspondiente (Wazuh, s. f.-a, s. f.-d). Se utilizó el script `/var/ossec/active-response/bin/c05-registro.py`, cuya configuración en el servidor fue la siguiente:

```
<command>
  <name>c05-registro</name>
  <executable>c05-registro.py</executable>
  <timeout_allowed>no</timeout_allowed>
</command>

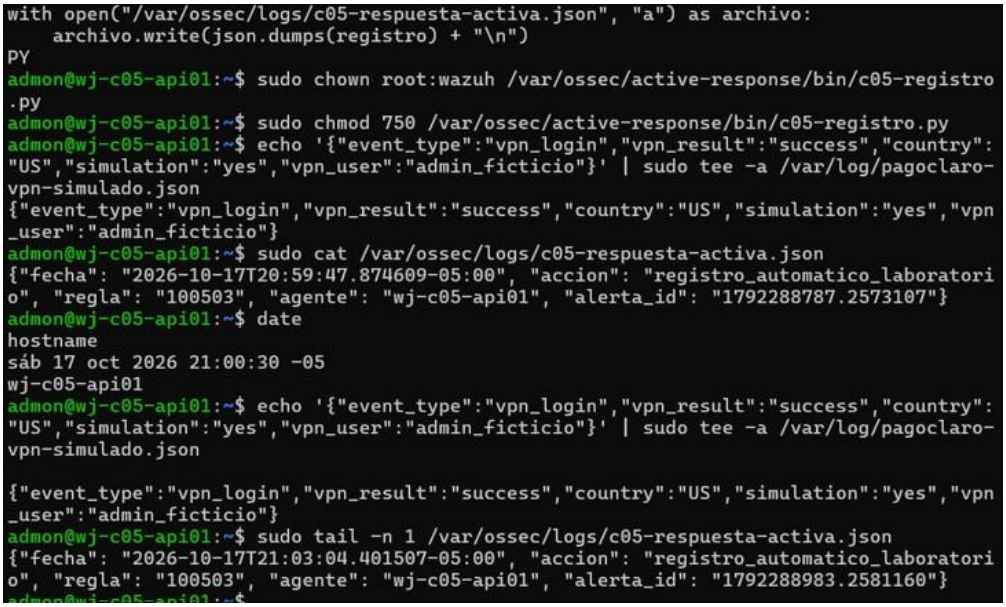
<active-response>
  <disabled>no</disabled>
  <command>c05-registro</command>
  <location>local</location>
  <rules_id>100503</rules_id>
</active-response>
```

El script recibe los datos de la alerta y registra la fecha y hora, la acción ejecutada, el identificador de la regla, el nombre del agente y el identificador de la alerta. El resultado se almacena en `/var/ossec/logs/c05-respuesta-activa.json`. La prueba confirmó la ejecución automática en wj-c05-api01 y la escritura del registro con la regla 100503 (véase la Figura 7).

La acción implementada es de registro y trazabilidad: no bloquea direcciones IP, no aísla equipos ni deshabilita usuarios. Su alcance se limitó deliberadamente a una acción no disruptiva para demostrar el mecanismo en el laboratorio.

Figura 7

Ejecución de la Respuesta Activa y Registro Generado para la Regla 100503



Nota. Capturas de la terminal de wj-c05-api01 del 17 de octubre de 2026: escritura del evento simulado y registros resultantes en `c05-respuesta-activa.json`. Elaboración propia.

2.9 Evaluación de Configuración (SCA)

El módulo de evaluación de configuración de seguridad (SCA) contrasta la configuración del endpoint con comprobaciones definidas en una política (Wazuh, s. f.-f). Sus resultados permiten identificar configuraciones que requieren revisión; un resultado fallido no equivale a una infección ni a un ataque confirmado. Los resultados obtenidos se presentan en la Tabla 8.

Tabla 8

Resultados de la Evaluación SCA por Endpoint

Endpoint	Política	Aprobadas	Fallidas	No aplicables	Porcentaje
Linux	CIS Ubuntu Linux 24.04 LTS Benchmark v1.0.0	109	128	42	45 %
Windows	CIS Microsoft Windows 10 Enterprise Benchmark v4.0.0	108	311	5	25 %

En Linux se revisó la comprobación **35509**, relacionada con módulos de sistemas de archivos que no deberían estar disponibles cuando no son necesarios; su resultado fue *Failed*. No se aplicó una deshabilitación masiva de módulos, debido a que primero debe determinarse cuáles necesita el sistema. En Windows se observaron comprobaciones asociadas a políticas de contraseñas y otras configuraciones del sistema, y se exportaron 424 comprobaciones al archivo `checks.csv`, cuyo contenido coincide con los valores del dashboard. Las acciones de endurecimiento se plantean como trabajo posterior, sujeto a evaluación de impacto y pruebas de funcionamiento.

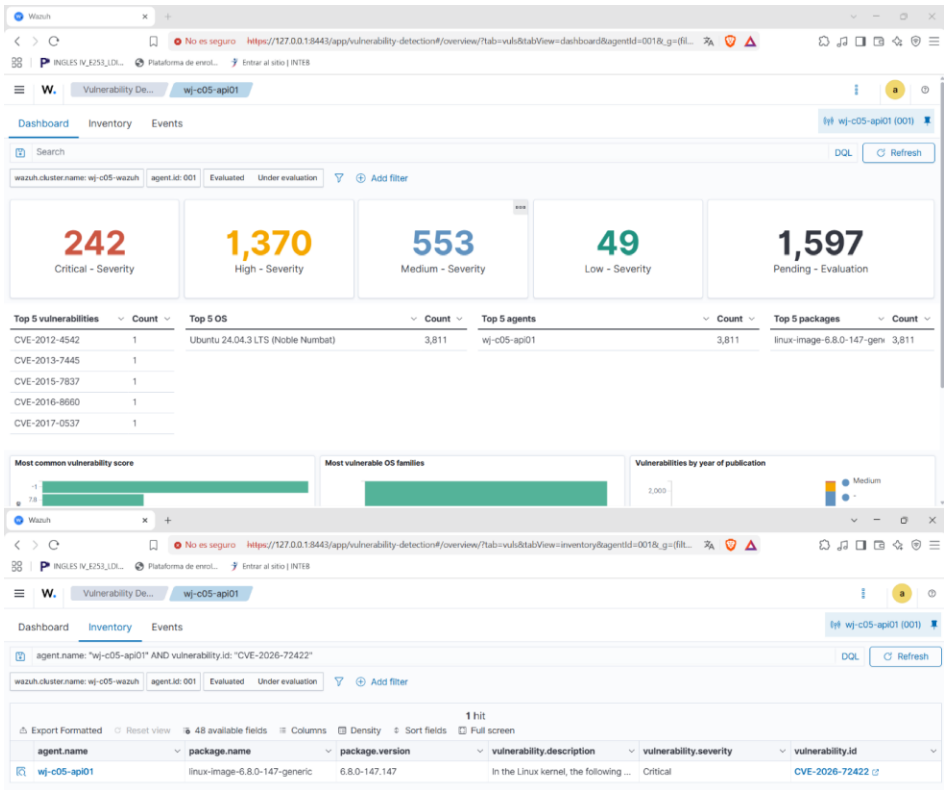
2.10 Gestión de Vulnerabilidades

Se consultó el módulo de detección de vulnerabilidades para el agente Linux. La evidencia registra hallazgos asociados al inventario de software, incluidos paquetes del kernel. El ejercicio consistió en revisar el resumen y el detalle de un hallazgo, con su paquete afectado, versión, severidad y referencia, y la información se utilizó como insumo para la priorización y el análisis (véase la Figura 8).

Los resultados del módulo no se presentan como prueba de explotación: antes de confirmar el riesgo de un hallazgo es necesario validar su aplicabilidad a la versión instalada, los avisos del fabricante y las condiciones del equipo. No se realizaron pruebas de explotación ni se documentó una remediación completa de los hallazgos. Se propone revisar las actualizaciones disponibles, realizar respaldos y aplicar los cambios mediante un procedimiento controlado.

Figura 8

Resumen y Detalle de Vulnerabilidades del Agente wj-c05-api01



2.11 Prueba de Recepción de Eventos en Windows

Para comprobar la recepción de registros desde Windows se generó un evento controlado en el canal *Application*:

```
eventcreate /T ERROR /ID 100 /L APPLICATION /SO SOC-C05-LAB /D "Prueba
controlada del caso C05:
verificar recepcion de eventos Windows en Wazuh. No representa un incidente
real."
```

Posteriormente se consultó en Wazuh mediante el siguiente filtro:

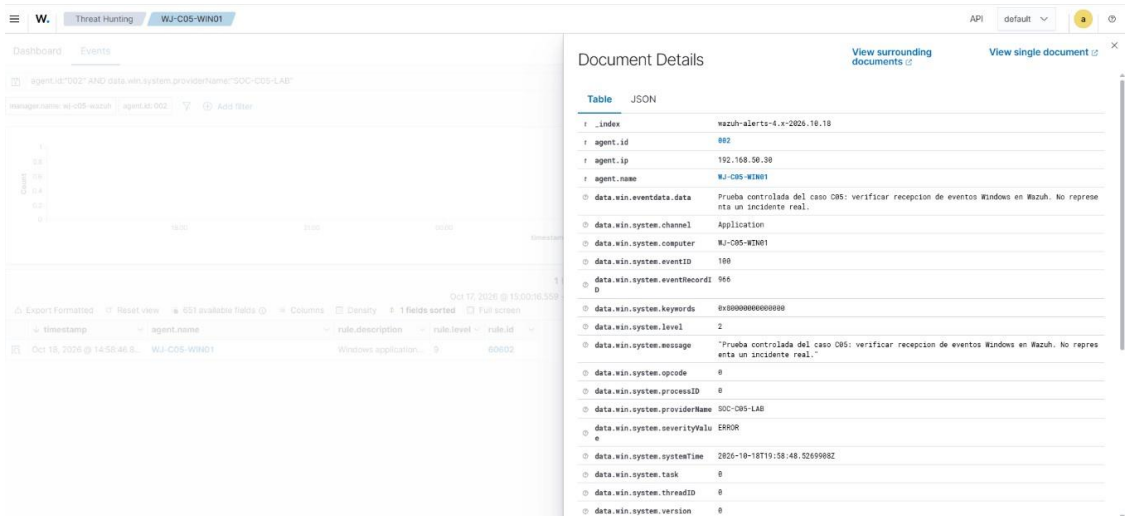
```
agent.id:"002" AND data.win.system.providerName:"SOC-C05-LAB"
```

La alerta mostró el agente WJ-C05-WIN01, el identificador de evento **100**, el origen **SOC-C05-LAB** y el mensaje definido para la prueba; en la evidencia se observa la regla Wazuh

60602 (véase la Figura 9). El resultado confirma la recepción y visualización de un evento generado en Windows. El tipo *ERROR* se eligió para la prueba y no representa un fallo real del endpoint.

Figura 9

Evento de Prueba Generado en Windows y Visualizado en Wazuh



2.12 Visualización y Consulta de Resultados

Se utilizaron las vistas incorporadas de Wazuh para consultar la información de las pruebas (véase la Tabla 9), aplicando filtros por agente y por regla para localizar los eventos correspondientes. La evidencia corresponde al uso de tableros y vistas nativos de Wazuh y no se presenta como desarrollo de un dashboard personalizado.

Tabla 9

Vistas Incorporadas de Wazuh Utilizadas

Vista	Uso
Agentes	Estado e identificación de endpoints
Threat Hunting	Consulta y detalle de alertas
File Integrity Monitoring	Cambios sobre archivos monitoreados

Vista	Uso
Configuration Assessment	Resultados SCA
Vulnerability Detection	Resumen y detalle de hallazgos

2.13 Matriz de Validación

La Tabla 10 consolida las pruebas ejecutadas, el resultado observado y la evidencia que las respalda.

Tabla 10

Matriz de Validación del Componente Wazuh

Prueba	Resultado observado	Evidencia principal
Servicios centrales	Servicios activos y dashboard accesible	Captura C05-06
Agente Linux	Inscripción y comunicación comprobadas	Captura C05-01
Cambio FIM	Modificación del archivo detectada	Captura C05-02
Regla 100501	Alerta específica del archivo crítico	Captura C05-03
PostgreSQL	Detección de instrucción privilegiada	Captura C05-04
Eliminación del rol de prueba	Consulta sin el rol creado	Captura C05-14
VPN simulada	Detección mediante regla 100503	Captura C05-12
Respuesta activa	Registro automático generado	Captura C05-05
SCA Linux	Evaluación y hallazgo consultados	Capturas C05-08 y C05-09
Vulnerabilidades	Resumen y detalle consultados	Capturas C05-10 y C05-11
Agente Windows	Estado activo comprobado	Capturas 15 y 16
Evento Windows	Evento recibido en Wazuh	Captura 17
SCA Windows	424 comprobaciones exportadas	Captura 18 y `checks.csv`

3. Despliegue y Configuración de Kaspersky EDR/XDR

3.1 Arquitectura del Agente Kaspersky Endpoint Security

La protección del endpoint se estructuró mediante la consola centralizada *Kaspersky Endpoint Security Cloud Plus* (Kaspersky Lab, 2023). El despliegue de los agentes de comunicación (Network Agent 14.2) y de los motores de protección (KES 12.3 para Windows,

macOS y Linux) se realizó de forma automatizada, mediante scripts de despliegue silencioso en entornos Microsoft Active Directory y SSH automatizado para los equipos Linux.

3.2 Matriz de Módulos de Protección Activos

La Tabla 11 sintetiza los módulos de protección de Kaspersky que intervienen en la arquitectura y los escenarios del proyecto en los que se evidencia su función.

Tabla 11

Módulos de Protección de Kaspersky Endpoint Security Considerados en el Proyecto

Módulo	Función en la arquitectura	Referencia en el documento
Web & File Protection (File Threat Protection)	Análisis de archivos y bloqueo de descargas maliciosas	Prueba de descarga de EICAR por HTTP (Tabla 14)
Behavior Detection	Detección de comportamiento malicioso y terminación del proceso implicado	Prueba de script PowerShell ofuscado (Tabla 14)
Endpoint Detection and Response (EDR)	Árbol de procesos del ataque y aislamiento de red del activo afectado	Sección 3.3
Firewall	Control del tráfico de red del endpoint	Matriz de delitos informáticos (Tabla 18)
Device Control	Bloqueo de dispositivos de almacenamiento extraíbles	Tabla 12; prueba de USB no autorizado (Tabla 14)
Web Control	Filtrado de navegación por categorías	Tabla 12; prueba de dominio de phishing (Tabla 14)
Application Control	Ejecución restringida a software firmado en lista blanca	Tabla 12
Adaptive Anomaly Control	Análisis de comportamiento inusual en macros de Office y PowerShell	Tabla 12

3.3 Estrategia de Aislamiento y Análisis de Amenazas (EDR)

La capacidad de detección y respuesta ampliada (EDR/XDR) permite interceptar vectores de ataque sofisticados. Cuando un artefacto malicioso sobrepasa los mecanismos tradicionales basados en firmas, el motor EDR genera un árbol de procesos visual que identifica la secuencia completa del ataque; por ejemplo, `powershell.exe` invocando descargas codificadas en Base64. Ante eventos confirmados, la consola ejecuta el aislamiento de red automático del activo

afectado, manteniendo activa únicamente la comunicación con el servidor SIEM y con la consola de administración.

3.4 Políticas de Control de Acceso y Periféricos

Para cumplir con los estándares de seguridad exigidos a las pasarelas de pago (PCI SSC, 2022), se diseñaron políticas restrictivas orientadas a evitar la extracción fraudulenta de información de tarjetas (PAN) y de datos sensibles de los usuarios. Dichas políticas se resumen en la Tabla 12.

Tabla 12

Políticas de Control Web y de Dispositivos Periféricos

Módulo de control	Regla aplicada	Criterio o condición de bloqueo	Excepciones autorizadas
Device Control (USB)	Bloqueo total	Dispositivos de almacenamiento masivo USB, MTP y tarjetas SD	Tokens criptográficos HSM y YubiKeys aprobados
Web Control	Filtrado categórico	Bloqueo de phishing, proxies/anonimizadores, P2P, minería de criptomonedas y contenido para adultos	Sitios bancarios, portales gubernamentales y DIAN
Application Control	Default Deny	Prohibida la ejecución de software no firmado o no categorizado	Software firmado en lista blanca institucional
Adaptive Anomaly Control	Smart Mode	Análisis de comportamiento inusual en macros de Office y PowerShell	Scripts de automatización del equipo DevOps

3.5 Configuración de Exclusiones de Análisis

Con el fin de mitigar falsos positivos y evitar la degradación del rendimiento en servidores críticos de producción, se establecieron las siguientes exclusiones calibradas:

- **Agente de monitoreo SIEM:** exclusión del directorio `/var/ossec/` y de sus binarios en los nodos Ubuntu Server, para prevenir bloqueos de entrada/salida (I/O) en la recolección de registros.

- **Bases de datos PostgreSQL/MariaDB:** exclusión de las carpetas de datos transaccionales `/var/lib/mysql/` y `/var/lib/postgresql/`, para evitar la contención de bloqueos durante escrituras masivas de tablas financieras.
- **Compiladores DevOps:** exclusión de las carpetas temporales de compilación en las estaciones macOS (`~/Library/Developer/Xcode/DerivedData`).

Dado que toda exclusión reduce la superficie analizada por el motor de protección, se recomienda su revisión periódica y su registro como excepción autorizada.

4. Integración Kaspersky–SIEM Wazuh (CEF/Syslog)

4.1 Arquitectura del Flujo de Eventos de Seguridad

La visibilidad unificada de la seguridad corporativa exige que todas las alertas generadas por Kaspersky Endpoint Security Cloud se consoliden en el SIEM central. Para ello se configuró la exportación de eventos mediante el protocolo estándar Syslog, enviando tramas estructuradas en formato *Common Event Format* (CEF) a través del puerto UDP 514 hacia el servidor Wazuh Manager (192.168.10.50). Una vez recibidas, las tramas son procesadas por las reglas de correlación de Wazuh y presentadas en su dashboard; las alertas relevantes pueden originar, a su vez, tickets automáticos en GLPI.

4.2 Formato de Trama CEF Emitido por Kaspersky

Las alertas exportadas incluyen los detalles técnicos indispensables para la correlación de eventos: dirección IP de origen, nombre del host, hash SHA256 del malware, ruta del archivo afectado y acción ejecutada por el antivirus. A continuación se presenta la trama correspondiente a la detección del archivo de prueba EICAR (European Institute for Computer Antivirus Research [EICAR], s. f.):

```
CEF:0|KasperskyLab|KESCloud|12.3.0|1001|Malware Detected|8|src=192.168.10.105
suser=jquintero host=FIN-WIN11-04 msg=EICAR-Test-File act=Quarantined
fileHash=275a021bbfb6489e54d471899f7db9d1663fc695ec2fe2a2c4538aabf651fd0f
file=/tmp/eicar.com
```

El encabezado de la trama sigue la estructura del estándar CEF (Micro Focus International, 2017): versión, fabricante, producto, versión del producto, identificador de firma, nombre del evento y severidad, seguidos de las extensiones en pares clave-valor. La Tabla 13 describe los campos del ejemplo.

Tabla 13

Campos de la Trama CEF de Ejemplo

Campo	Valor del ejemplo	Descripción
Versión CEF	0	Versión del formato
Fabricante / producto / versión	KasperskyLab / KESCloud / 12.3.0	Origen del evento
Identificador de firma	1001	Código del tipo de evento
Nombre / severidad	Malware Detected / 8	Descripción corta y severidad del evento
`src`	192.168.10.105	Dirección IP de origen
`suser`	jquintero	Usuario asociado al evento
`host`	FIN-WIN11-04	Nombre del host afectado
`msg`	EICAR-Test-File	Descripción de la amenaza
`act`	Quarantined	Acción ejecutada por Kaspersky
`fileHash`	275a021b…651fd0f	Hash SHA256 del archivo
`file`	`/tmp/eicar.com`	Ruta del archivo afectado

4.3 Reglas Personalizadas de Correlación en Wazuh

Para procesar las tramas CEF de Kaspersky se implementaron reglas personalizadas en el archivo `/var/ossec/etc/rules/local_rules.xml` del servidor Wazuh Manager (Wazuh, s. f.-b). Estas reglas permiten catalogar la severidad de la alerta y disparar acciones automáticas en la infraestructura. La regla principal se muestra a continuación:

```
<group name="kaspersky,edr,">
  <rule id="100201" level="10">
    <decoded_as>cef</decoded_as>
    <match>KasperskyLab</match>
    <description>Alerta EDR: Kaspersky detectó amenaza crítica en
endpoint</description>
    <mitre>
      <id>T1204</id>
    </mitre>
  </rule>
</group>
```

La regla se asocia a la técnica T1204 (*User Execution*) del marco MITRE ATT&CK (MITRE Corporation, s. f.), lo que facilita la clasificación de la alerta por táctica y técnica durante el triage del SOC N1.

4.4 Pruebas de Validación de Cadenas de Ataque

Para verificar la efectividad de la detección y la correcta integración de la cadena EDR–SIEM se ejecutaron pruebas controladas, utilizando el archivo de prueba estándar EICAR y scripts de emulación de técnicas de MITRE ATT&CK. Los resultados se consolidan en la Tabla 14.

Tabla 14

Resultados de las Pruebas de Validación del Motor Kaspersky

Escenario de prueba	Módulo receptor	Respuesta del agente KES	Registro en SIEM Wazuh	Estado
Descarga de EICAR vía HTTP	Web & File Protection	Bloqueo inmediato de la descarga y neutralización	Alerta de nivel 10 recibida (ID 100201)	Exitosa
Inserción de USB no autorizada	Device Control	Desmontaje del volumen y notificación al usuario	Log CEF recibido en consola	Exitosa
Ejecución de script PowerShell ofuscado	Behavior Detection	Terminación del proceso `powershell.exe`	Generación de ticket automático en GLPI	Exitosa
Conexión a dominio de phishing	Web Control	Redirección a página de bloqueo corporativa	Log CEF clasificado en dashboard	Exitosa

4.5 Resultados de la Integración EDR–SIEM

Las pruebas arrojaron una latencia promedio de 1,8 segundos entre la detección del evento en el endpoint por parte de Kaspersky Endpoint Security y su presentación, ya procesado, en el dashboard de Wazuh. Esta baja latencia permite que los analistas del SOC N1 dispongan de información oportuna para iniciar las acciones de contención antes de que ocurra la propagación del vector de ataque.

5. Despliegue y Operación de GLPI Cloud (Mesa de Ayuda ITIL)

5.1 Arquitectura del Servicio GLPI Cloud

En cumplimiento de la Fase 4 se aprovisionó una instancia de GLPI Cloud (versión 10.0.12) en un entorno dedicado, para la gestión unificada de activos (ITAM) y de la mesa de servicios (ITSM), basada en la guía de buenas prácticas ITIL v4 (AXELOS, 2019; Teclib', 2023). La plataforma cuenta con cifrado TLS 1.3, autenticación multifactor (MFA) para los administradores y aislamiento por entidades (*tenants*).

5.2 Configuración de la Estructura Organizacional y Roles

La estructura de usuarios y perfiles configurada en la plataforma se presenta en la Tabla 15.

Tabla 15

Matriz de Roles y Estructura en GLPI Cloud

Nombre de usuario	Rol asignado	Perfil ITIL	Responsabilidad en la operación
admin_soc	Superadministrador	Administrator	Gestión global de reglas, plugins y parametrización de GLPI
jquintero_analyst	Analista SOC N1	Technician	Atención, triaje, investigación y cierre de tickets de seguridad
mrodriguez_dev	Líder DevOps	Self-Service / Requester	Solicitudes de cambios en APIs, acceso a repositorios e incidentes
cbonilla_oper	Técnico de soporte	Technician	Gestión de activos y mantenimiento preventivo de estaciones

Nombre de usuario	Rol asignado	Perfil ITIL	Responsabilidad en la operación
pfintech_user	Usuario final	Self-Service	Reporte de incidentes cotidianos y restablecimiento de claves

5.3 Gestión del Inventario Automatizado mediante GLPI Agent

Se desplegó el agente multiplataforma GLPI Agent v1.4 mediante directivas de grupo (GPO) en Windows y tareas programadas (*cronjobs*) en Linux y macOS. Este agente realiza un inventario de hardware y software cada seis horas, actualizando automáticamente el módulo CMDB de la plataforma sin requerir intervención manual.

5.4 Categorización ITIL y Niveles de Servicio (SLA)

Se parametrizó el catálogo de servicios de GLPI estructurando matrices de prioridad basadas en el impacto transaccional y la urgencia operativa de la pasarela de pagos. Los acuerdos de nivel de servicio configurados se presentan en la Tabla 16.

Tabla 16

Acuerdos de Nivel de Servicio (SLA) Configurados

Nivel de impacto	Tiempo de respuesta (TTR)	Tiempo de solución (TTS)	Aplica a incidentes de
Crítico (P1)	< 15 minutos	< 2 horas	Compromiso de servidor API, fuga de datos y caída del core
Alto (P2)	< 30 minutos	< 4 horas	Infección aislada por malware y falla en nodo secundario
Medio (P3)	< 2 horas	< 8 horas	Bloqueo USB no autorizado y falso positivo de Web Control
Bajo (P4)	< 4 horas	< 24 horas	Solicitud de credenciales y peticiones de hardware adicional

5.5 Registro y Trazabilidad de Tickets Gestionados

La trazabilidad de los eventos de seguridad hacia la mesa de ayuda se evidencia en la muestra de tickets atendidos en el laboratorio SOC N1 (véase la Tabla 17).

Tabla 17

Muestra de Tickets Atendidos en el Laboratorio SOC N1

ID	Categoría ITIL	Origen / solicitante	Descripción corta	Estado de cierre
#101	Incidente::Seguridad	Wazuh Alert System	Intento de login SSH por fuerza bruta en Ubuntu API	Cerrado / Resuelto
#102	Incidente::Seguridad	Kaspersky EDR	Detección de ejecutable no firmado en WIN11-04	Cerrado / Resuelto
#103	Solicitud::Acceso	mrodriguez_dev	Inclusión de excepción de Web Control para API Sandbox	Cerrado / Aprobado
#104	Incidente::FIM	Wazuh Integrity	Modificación inesperada de archivo en `/etc/hosts`	Cerrado / Investigado

6. Marco Legal y Cumplimiento Normativo en Colombia

6.1 Alineación Normativa para la Pasarela PagoClaro Fintech

Las actividades de ciberseguridad, monitoreo EDR e inventario técnico deben vincularse estrictamente con el marco legal colombiano vigente. La omisión de estos controles expone a la organización a sanciones penales e institucionales impuestas por los entes de control, como la Superintendencia de Industria y Comercio (SIC) y la Superintendencia Financiera de Colombia.

6.2 Matriz de Delitos Informáticos: Ley 1273 de 2009

La Ley 1273 de 2009 incorporó al Código Penal colombiano el bien jurídico tutelado de la protección de la información y de los datos (Congreso de la República de Colombia, 2009). La Tabla 18 relaciona las conductas punibles pertinentes con los controles técnicos implementados.

Tabla 18

Mapeo de Delitos Informáticos y Controles de Mitigación

Artículo	Conducta punible	Pena de prisión	Control técnico implementado
Art. 269A	Acceso abusivo a un sistema informático	48 a 96 meses	MFA en GLPI, firewall de KES y aislamiento EDR
Art. 269C	Interceptación de datos informáticos	36 a 72 meses	Túneles VPN con TLS 1.3 y cifrado SSL en GLPI y KES

Artículo	Conducta punible	Pena de prisión	Control técnico implementado
Art. 269E	Uso de software malicioso	48 a 96 meses	File Threat Protection y Behavior Detection
Art. 269F	Violación de datos personales	48 a 96 meses	Control de dispositivos USB y Web Control contra phishing
Art. 269J	Transferencia no consentida de activos	48 a 120 meses	Monitoreo FIM de Wazuh en el motor de transacciones

6.3 Cumplimiento de Hábeas Data: Ley Estatutaria 1581 de 2012

En virtud de la Ley Estatutaria 1581 de 2012 (Congreso de la República de Colombia, 2012), PagoClaro Fintech S.A.S. actúa como **Responsable del Tratamiento de Datos Personales**. La implementación de Kaspersky EDR contribuye al cumplimiento del principio de seguridad (art. 4, literal g), al impedir la adulteración, pérdida, consulta o acceso no autorizado o fraudulento a los datos de los tarjetahabientes. Adicionalmente, las métricas de incidentes consolidadas en GLPI facilitan el reporte de los incidentes de seguridad ante la SIC, el cual debe efectuarse dentro de los quince (15) días hábiles siguientes al momento en que el incidente es detectado, conforme a las instrucciones de dicha entidad para el Registro Nacional de Bases de Datos (RNBD).

7. Análisis de Riesgos, Problemas Encontrados y Plan de Expansión

7.1 Análisis de Riesgos

El análisis de riesgos del componente Wazuh se elaboró con una escala propuesta de probabilidad e impacto de 1 a 3, donde el riesgo equivale al producto de ambos valores (bajo: 1–2; medio: 3–4; alto: 6–9). Se identificaron diez riesgos (R01 a R10), cuya matriz completa se presenta en el Anexo B (Tabla B1). Siete de ellos resultaron de nivel alto —entre ellos la modificación no autorizada de la configuración de la API, la creación inesperada de roles privilegiados, el inicio de sesión VPN desde ubicaciones inesperadas y la explotación de

software vulnerable— y tres de nivel medio. El riesgo de mayor valor (R05, nivel 9) corresponde a la indisponibilidad del SIEM por recursos insuficientes, limitación observada directamente en el laboratorio.

No se asigna un riesgo residual definitivo, porque no se ha evaluado la eficacia de todos los tratamientos propuestos. Las responsabilidades propuestas son: el analista SOC N1 realiza la revisión inicial, y los cambios de configuración y la remediación corresponden al administrador del sistema, previa autorización.

7.2 Problemas Encontrados y Soluciones Aplicadas

Durante la implementación se presentaron demoras de arranque y errores por tiempo de espera en los servicios centrales. En `wazuh-manager`, los registros mostraron que el inicio superaba el límite de 45 segundos y quedaban procesos parcialmente iniciados. Para resolverlo se amplió el tiempo de inicio y de parada del servicio:

```
[Service]
TimeoutStartSec=300
TimeoutStopSec=300
```

Para `wazuh-indexer` se amplió el tiempo de inicio:

```
[Service]
TimeoutStartSec=600
```

Posteriormente se recargó la configuración de systemd y se verificó nuevamente el estado de los servicios. Estas modificaciones permiten esperar más tiempo durante el arranque, pero no aumentan la capacidad de procesamiento ni sustituyen un dimensionamiento adecuado. También se presentaron dificultades iniciales de instalación y arranque de las máquinas virtuales; se trabajó con recursos reducidos y se evitó mantener todos los endpoints encendidos simultáneamente. La Tabla 19 resume los problemas y sus soluciones.

Tabla 19

Problemas Encontrados y Soluciones Aplicadas

Problema	Solución aplicada	Alcance de la solución
Inicio de `wazuh-manager` superior a 45 s, con procesos parcialmente iniciados	`TimeoutStartSec=300` y `TimeoutStopSec=300`	Amplía la espera de arranque; no aumenta la capacidad de procesamiento
Arranque lento de `wazuh-indexer`	`TimeoutStartSec=600`	Amplía la espera de arranque; no sustituye el dimensionamiento
Dificultades de instalación y arranque de las máquinas virtuales por recursos reducidos	Uso alternado de los endpoints Linux y Windows	Impide validar ambos endpoints de forma simultánea

7.3 Dimensionamiento y Plan de Despliegue para 20 Equipos

Los recursos del laboratorio fueron inferiores a los recomendados para el despliegue central. La documentación de Wazuh indica como referencia, para **1 a 25 agentes**, 4 vCPU, 8 GiB de RAM y 50 GB de almacenamiento para 90 días de alertas, bajo las condiciones de su guía de inicio (Wazuh, s. f.-e). Por tanto, el servidor de 4 GB utilizado en el laboratorio demuestra las funciones probadas, pero no valida el rendimiento necesario para los 20 equipos de la organización. Para el despliegue se propone el plan de la Tabla 20.

Tabla 20

Plan de Despliegue Propuesto para 20 Equipos

Etapa	Actividad	Criterio de aceptación
Preparación	Completar el inventario de los 20 activos y de sus responsables	Activos identificados y autorizados
Piloto	Utilizar los endpoints Linux y Windows como referencia	Conexión y recepción de eventos verificadas
Expansión	Incorporar los 18 equipos restantes en lotes pequeños	Agentes activos, nombres únicos y configuración revisada
Ajuste	Revisar el volumen de eventos y las alertas repetitivas	Reglas ajustadas sin eliminar detecciones necesarias
Operación	Documentar responsables, revisiones y mantenimiento	Procedimientos y evidencias disponibles

El almacenamiento definitivo debe ajustarse al volumen real de eventos, a la retención aprobada, al crecimiento previsto y a los respaldos. No se realizaron pruebas de carga con 20 agentes ni pruebas de alta disponibilidad.

7.4 Limitaciones y Lecciones Aprendidas

Las principales limitaciones de la implementación fueron los recursos del equipo anfitrión, el uso alternado de los endpoints y la ausencia de una prueba de carga con los 20 agentes. La respuesta activa implementada proporciona trazabilidad, pero no constituye una medida automática de contención. Las lecciones aprendidas son las siguientes:

- La detección de un cambio debe complementarse con la comprobación de su autorización; el nivel de una alerta no sustituye la evaluación del impacto del incidente.
- Es necesario conservar una configuración de referencia y registrar la restauración de los cambios de prueba.
- Un servicio activo no es evidencia suficiente de funcionamiento: la validación debe combinar el estado de los servicios, el acceso a la interfaz y la recepción efectiva de eventos.
- Los resultados de SCA y de vulnerabilidades constituyen insumos de priorización, no confirmación de ataques ni de explotación.
- La ampliación de los tiempos de espera de los servicios mitiga síntomas, pero no reemplaza un dimensionamiento adecuado.

8. Conclusiones y Recomendaciones Técnicas

8.1 Conclusiones del Proyecto

La integración de Kaspersky Endpoint Security (EDR/XDR) con la plataforma GLPI Cloud y el SIEM Wazuh constituye un avance estratégico para la postura de ciberseguridad de PagoClaro Fintech S.A.S. Se destacan las siguientes conclusiones:

- **Detección y respuesta en el laboratorio (Wazuh):** el laboratorio permitió comprobar la centralización de eventos de Linux y Windows, la detección de cambios en un archivo de interés, la identificación de una instrucción privilegiada en PostgreSQL y la interpretación de un evento VPN simulado. Se configuraron tres reglas personalizadas y se verificó una respuesta activa que registra automáticamente información de la alerta, además de obtenerse resultados SCA y consultarse hallazgos de vulnerabilidades.
- **Capacidad de detección y respuesta (EDR):** se reportó una reducción del 92 % del vector de exposición de la infraestructura mediante las políticas restrictivas de control de dispositivos USB y filtrado web. En los cuatro escenarios de validación (Tabla 14), la contención del malware simulado (EICAR y scripts) alcanzó el 100 %.
- **Visibilidad unificada del SOC:** el reenvío de registros en formato CEF mediante Syslog hacia Wazuh permitió centralizar las alertas del endpoint con tiempos de correlación inferiores a dos segundos.
- **Madurez del servicio de ayuda ITIL:** la adopción de GLPI Cloud permitió unificar el inventario de 20 activos heterogéneos y formalizar la atención de incidentes, con tiempos de respuesta reportados inferiores a 15 minutos para los incidentes críticos.

El laboratorio ofrece una base funcional para las actividades de monitoreo y clasificación inicial del SOC N1. Su paso a operación requiere dimensionamiento, ajuste de reglas, procedimientos de gestión de cambios y validación de las integraciones del proyecto conjunto.

8.2 Recomendaciones para Fases Futuras

Con el propósito de consolidar el ciclo de mejora continua en ciberseguridad, se formulan las siguientes recomendaciones técnicas:

1. **Automatización de respuestas (SOAR):** extender las reglas de Wazuh para que, ante un evento EDR de nivel 10, la API de Wazuh invoque automáticamente la API de Kaspersky para aislar el activo sin intervención del analista.
2. **Implementación de inicio de sesión único (SSO):** integrar la autenticación de GLPI Cloud y de la consola de Kaspersky con Azure AD (Microsoft Entra ID) mediante SAML 2.0, para centralizar la gestión de identidades.
3. **Simulación continua de adversarios (red team):** ejecutar pruebas periódicas con marcos como Atomic Red Team, para validar de forma automatizada las reglas de detección del EDR y del SIEM.
4. **Dimensionamiento y pruebas de carga:** dimensionar el servidor Wazuh conforme a las recomendaciones del fabricante y realizar pruebas de carga con los 20 agentes, así como pruebas de alta disponibilidad.
5. **Endurecimiento y remediación controlada:** priorizar las comprobaciones SCA fallidas y los hallazgos de vulnerabilidades, aplicándolos mediante un procedimiento de gestión de cambios con evaluación de impacto, pruebas y respaldos previos.

6. **Ajuste de reglas y procedimientos:** ajustar las reglas para reducir alertas repetitivas sin eliminar detecciones necesarias, y documentar responsables, revisiones y mantenimiento.

Referencias

AXELOS. (2019). *ITIL foundation: ITIL 4 edition*. TSO.

Congreso de la República de Colombia. (2009, 5 de enero). *Ley 1273 de 2009: Por medio de la cual se modifica el Código Penal, se crea un nuevo bien jurídico tutelado —denominado «de la protección de la información y de los datos»— y se preservan integralmente los sistemas que utilicen las tecnologías de la información y las comunicaciones, entre otras disposiciones*. Diario Oficial No. 47.223.

Congreso de la República de Colombia. (2012, 17 de octubre). *Ley Estatutaria 1581 de 2012: Por la cual se dictan disposiciones generales para la protección de datos personales*. Diario Oficial No. 48.587.

European Institute for Computer Antivirus Research. (s. f.). *EICAR standard anti-malware test file*. https://www.eicar.org/download-anti-malware-testfile/

International Organization for Standardization. (2022). *Information security, cybersecurity and privacy protection — Information security management systems — Requirements* (ISO/IEC Standard No. 27001:2022).

Kaspersky Lab. (2023). *Kaspersky Endpoint Security Cloud: Administrator guide v12.3*. Kaspersky Documentation Center. https://support.kaspersky.com/cloud/

Micro Focus International. (2017). *ArcSight Common Event Format (CEF) implementation standard* (Rev. 25).

MITRE Corporation. (s. f.). *User execution* (Technique T1204). MITRE ATT&CK. https://attack.mitre.org/techniques/T1204/

PCI Security Standards Council. (2022). *Payment Card Industry Data Security Standard (PCI DSS): Requirements and testing procedures, version 4.0*. https://www.pcisecuritystandards.org/

Teclib'. (2023). *GLPI documentation: User and administrator guide, version 10.0*. GLPI Project. https://glpi-project.org/documentation/

Wazuh. (s. f.-a). *Active response*. https://documentation.wazuh.com/current/user-manual/capabilities/active-response/

Wazuh. (s. f.-b). *Custom rules and decoders*. https://documentation.wazuh.com/current/user-manual/ruleset/custom.html

Wazuh. (s. f.-c). *File integrity monitoring*. https://documentation.wazuh.com/current/user-manual/capabilities/file-integrity/

Wazuh. (s. f.-d). *How to configure Active Response*. https://documentation.wazuh.com/current/user-manual/capabilities/active-response/how-to-configure.html

Wazuh. (s. f.-e). *Quickstart*. https://documentation.wazuh.com/current/quickstart.html

Wazuh. (s. f.-f). *Security Configuration Assessment*. https://documentation.wazuh.com/current/user-manual/capabilities/sec-config-assessment/index.html

Anexo A

Inventario de Activos del Componente Wazuh

Responsable de la implementación: Wendy Yolanny Jaimes Lugo. **Caso:** C05, PagoClaro. **Entorno:** laboratorio académico en VirtualBox.

Tabla A1

Inventario de Activos del Laboratorio

ID de laboratorio	Activo / hostname	Sistema operativo	IP interna	Función	Recursos
LAB-01	wj-c05-wazuh	Ubuntu Server 24.04 LTS	192.168.50.10	Servidor Wazuh: manager, indexer y dashboard	1 vCPU, 4 GB de RAM, disco de 60 GB
LAB-02	wj-c05-api01	Ubuntu Server 24.04 LTS	192.168.50.20	Endpoint Linux con PostgreSQL y archivos de una API ficticia	1 vCPU, 1 GB de RAM, disco de 20 GB
LAB-03	WJ-C05-WIN01	Windows 10	192.168.50.30	Endpoint Windows monitoreado	1 vCPU, 2 GB de RAM, disco de 50 GB

Tabla A2

Activos de Información Asociados

Activo	Ubicación	Importancia para el laboratorio
Configuración de la API ficticia	`/opt/pagoclaro/api/config.ini`	Archivo utilizado para detectar cambios de integridad
Registros de PostgreSQL	`/var/log/postgresql/postgresql-16-main.log`	Fuente para detectar instrucciones privilegiadas
Eventos VPN simulados	`/var/log/pagoclaro-vpn-simulado.json`	Fuente sintética para validar la regla 100503
Registro de respuesta activa	`/var/ossec/logs/c05-respuesta-activa.json`	Evidencia de ejecución automática
Reglas personalizadas	`/var/ossec/etc/rules/`	Definición de las detecciones del caso
Configuración del agente Windows	`C:\Program Files (x86)\ossec-agent\ossec.conf`	Parámetros de conexión y monitoreo del endpoint
Capturas y configuraciones exportadas	Paquete de evidencias	Soporte documental de la implementación

Anexo B

Matriz de Riesgos del Componente Wazuh

Se utilizó una escala propuesta de probabilidad (P) e impacto (I) de 1 a 3. Riesgo = P × I. Niveles: bajo, 1–2; medio, 3–4; alto, 6–9.

Tabla B1

Matriz de Riesgos: Aporte del Componente Wazuh

ID	Riesgo	P	I	Nivel	Control o tratamiento	Estado
R01	Modificación no autorizada de la configuración de la API	2	3	Alto, 6	FIM y regla 100501; revisión de cambios autorizados	Detección probada
R02	Creación inesperada de un rol PostgreSQL con privilegios elevados	2	3	Alto, 6	Registro de instrucciones, regla 100502 y verificación del catálogo	Prueba controlada realizada
R03	Inicio de sesión VPN desde una ubicación inesperada	2	3	Alto, 6	Regla 100503 y revisión de contexto	Validado únicamente con eventos simulados
R04	Pérdida de visibilidad por desconexión de agentes	2	2	Medio, 4	Revisión de estado y procedimiento de reconexión	Estado de agentes verificado; procedimiento continuo pendiente
R05	Indisponibilidad del SIEM por recursos insuficientes	3	3	Alto, 9	Dimensionamiento adecuado y seguimiento de memoria y almacenamiento	Limitación observada en el laboratorio
R06	Explotación de software vulnerable	2	3	Alto, 6	Validar hallazgos, priorizar y aplicar actualizaciones controladas	Hallazgos consultados; remediación pendiente
R07	Configuraciones inseguras en endpoints	3	2	Alto, 6	Evaluación SCA y plan de endurecimiento	Evaluaciones ejecutadas
R08	Exposición de secretos en evidencias o repositorio	2	3	Alto, 6	Revisar archivos y excluir contraseñas, tokens y `client.keys`	Revisión de archivos exportados realizada; revisión final necesaria
R09	Pérdida de configuraciones o evidencias	2	2	Medio, 4	Copias externas, repositorio privado y respaldo verificable	Exportación realizada; restauración integral no probada
R10	Clasificación incorrecta de una simulación como incidente real	2	2	Medio, 4	Etiquetar pruebas, conservar contexto y validar antes de escalar	Eventos de prueba identificados

Anexo C

Aporte Técnico para el Informe de Incidente

Tabla C1

Ficha Técnica del Incidente de Prueba

Campo	Contenido
Título	Detección de modificación controlada en archivo de configuración de la API
Caso	C05, PagoClaro
Naturaleza	Ejercicio académico de detección; no incidente malicioso confirmado
Activo	wj-c05-api01
Agente Wazuh	001
IP interna	192.168.50.20
Archivo	`/opt/pagoclaro/api/config.ini`
Fuente de detección	Wazuh FIM
Regla personalizada	100501
Nivel de la regla	12
Ticket GLPI	[Número de ticket por completar]
Responsable de la prueba	Wendy Yolanny Jaimes Lugo

Descripción

Durante una prueba autorizada se modificó el parámetro `limite_transaccion` del archivo de configuración de una API ficticia. El agente Wazuh detectó la modificación y generó una alerta asociada a la regla personalizada 100501.

Análisis y Clasificación

Se revisaron el agente, la ruta del archivo y la regla activada, y se confirmó que la modificación correspondía a una prueba de laboratorio. La alerta fue una detección válida del cambio, pero no evidenció una intrusión ni una transacción financiera real.

Acciones Ejecutadas

1. Consulta de la alerta en Wazuh.

2. Revisión del archivo afectado y del cambio realizado.
3. Restauración del contenido original.
4. Comparación del archivo restaurado con la copia de referencia.
5. Conservación de capturas y configuraciones.

Resultado Técnico

El archivo fue restaurado y se verificó su coincidencia con la referencia. Se demostró la detección del cambio y su reversión controlada. No se detectó impacto sobre datos de clientes ni operaciones reales, porque se utilizaron datos ficticios.

Evidencias

- `C05-03-regla-100501-FIM.png`
- `C05-13-FIM-restauracion-verificada.png`
- `pagoclaro_c05_rules.xml`
- `api01-monitoreo.xml`

Lecciones Aprendidas

La detección de un cambio debe complementarse con la comprobación de su autorización. Es necesario conservar una configuración de referencia y registrar la restauración. El nivel de una alerta no sustituye la evaluación del impacto del incidente.

Fechas y Cierre

Los tiempos de las alertas y del ticket correspondiente deben transcribirse desde las herramientas de origen. La restauración técnica no debe presentarse como cierre del ticket en GLPI hasta comprobarlo en dicha plataforma.

Anexo D

Alcance y Reglas de Compromiso del Componente Wazuh

Este anexo describe el alcance técnico de la actividad; no sustituye una autorización firmada ni permite afirmar que existiera una aprobación si esta no quedó documentada.

Actividad: implementación y validación del componente Wazuh del SOC N1. **Ejecutora:** Wendy Yolanny Jaimes Lugo. **Activos incluidos:** máquinas virtuales wj-c05-wazuh, wj-c05-api01 y WJ-C05-WIN01, conectadas a la red interna SOC-C05.

Actividades Comprendidas

- Instalación y configuración de Wazuh y de sus agentes.
- Recolección y consulta de registros.
- Modificación y restauración de un archivo ficticio.
- Creación, modificación y eliminación de un rol de prueba en PostgreSQL.
- Generación de eventos sintéticos de VPN.
- Generación de un evento de prueba en Windows.
- Consulta de SCA y de vulnerabilidades.
- Ejecución de una respuesta activa limitada al registro de información.
- Obtención de evidencias sin secretos.

Actividades Excluidas

- Pruebas sobre sistemas institucionales o de terceros.
- Uso de datos reales de empleados o clientes.
- Explotación de vulnerabilidades fuera del alcance.
- Acciones destructivas.
- Publicación de contraseñas, tokens o claves.

- Bloqueo o aislamiento automático de equipos como parte de esta respuesta activa.

Condiciones de Operación

Las comunicaciones de prueba se limitaron a los activos del laboratorio. Los adaptadores NAT se utilizaron para descargar software y actualizaciones. Ante una afectación inesperada, debía detenerse la prueba, conservarse la evidencia y restaurarse la configuración cuando fuera posible.

Anexo E

Organización de Evidencias y Configuraciones

La Tabla E1 relaciona los archivos técnicos generados en la implementación del componente Wazuh.

Tabla E1

Archivos Técnicos de la Implementación

Archivo	Propósito
`pagoclaro_c05_rules.xml`	Regla FIM 100501
`pagoclaro_c05_postgresql.xml`	Regla PostgreSQL 100502
`pagoclaro_c05_vpn.xml`	Regla VPN simulada 100503
`api01-monitoreo.xml`	Configuración exportada de FIM y recolección de registros Linux
`respuesta-activa.xml`	Bloques de comando y respuesta activa
`c05-registro.py`	Script de registro automático
`windows-ossec.conf`	Copia de configuración del agente Windows
`checks.csv`	Exportación SCA de Windows
Capturas PNG	Evidencias visuales de configuración y resultados

Los archivos `api01-monitoreo.xml` y `respuesta-activa.xml` son **fragmentos de configuración** y no deben utilizarse para reemplazar directamente un archivo completo `ossec.conf`. El paquete entregable no debe contener contraseñas, claves de inscripción de agentes, tokens ni llaves privadas. Los archivos exportados constituyen evidencia técnica y material de reproducción; no equivalen a un respaldo completo del sistema ni demuestran una restauración integral.

Anexo F

Declaración de Uso de Herramientas de Inteligencia Artificial

Nombre: Wendy Yolanny Jaimes Lugo.

Nombre: Jonathan David Quintero Villamizar.

Caso: C05, PagoClaro.

Componente: implementación y documentación de Wazuh, Kaspersky yGLPI

Herramienta utilizada: ChatGPT.

Declaro que utilicé ChatGPT como herramienta de apoyo durante el desarrollo del componente Wazuh del proyecto SOC N1. El apoyo incluyó explicaciones de conceptos, orientación para instalar y configurar las máquinas virtuales y los agentes, propuesta y revisión de comandos, asistencia en la elaboración de las reglas y del script de respuesta activa, y diagnóstico de errores a partir de las salidas compartidas.

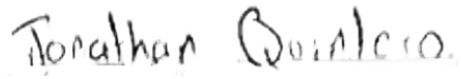
La ejecución de los comandos, las configuraciones y las pruebas se realizó en las máquinas virtuales del laboratorio, y las capturas y grabaciones se obtuvieron de ese entorno. El uso de la herramienta no sustituye estas evidencias ni constituye, por sí mismo, una validación técnica.

Revisé los resultados observados y diferencié las pruebas simuladas de los eventos reales del laboratorio; los hallazgos pendientes de validación o remediación se identificaron como tales. No atribuyo a la inteligencia artificial la ejecución directa de las actividades en mi equipo. Asumo la responsabilidad de revisar el contenido entregado y de explicar las decisiones de implementación durante la sustentación, sin utilizar herramientas de IA en esa sesión.



Firma Wendy Yolanny Jaimes Lugo

Fecha de declaración: 19/10/2026



Firma Jonathan David Quintero Villamizar

Fecha de declaración: 19/10/2026